

Verslag managementreview

Dit template is gemaakt door de mensen van ICT Institute.
Het template mag gratis worden gebruikt, onder een creative commons licentie
<https://creativecommons.org/licenses/by/4.0/>

De nieuwste versie staat op:
<https://softwarezaken.nl/2022/01/gratis-27001-avg-templates/>

Je mag het template uitbreiden, aanpassen en bewerken zoveel je wilt
Je mag het template en documenten gemaakt met het template doorgeven en delen
zoveel je wilt.

Als je het template doorgeeft, dan moet je "gemaakt door de mensen van ICT Institute"
laten staan.

Als je een document maakt met dit template en je bent geen opdrachtgever van ons, zet
dan "gemaakt met template van ICT Institute" ergens in het document

Als je een opdrachtgever bent van ICT Institute, dan mag je alles doen met dit template
wat je wilt.

Let op dat je de ISO 27001 norm moet kopen bij NEN of een andere organisatie voordat
je de norm gaat gebruiken. De norm is auteursrechtelijk beschermd.

Dit document bevat het verslag van de directiebeoordeling van het managementsysteem voor informatiebeveiliging (ISMS) van [ORGANISATIE] uitgevoerd op [DATUM].
Dit verslag is gemaakt door:

Aanwezigen

1. (CEO)
2. (CTO)
3. (CISO)

Agenda

1. Status van acties uit vorige review
2. Wijzigingen in interne en externe onderwerpen van belang voor ISMS
3. Wijzigingen in behoeften / verwachtingen belanghebbenden relevant voor ISMS
4. Feedback op prestaties, gebaseerd op:
 - o Afwijkingen (uit externe audit, interne audits of andere controles)
 - o Resultaten monitoren en meten
 - o Auditresultaten
 - o Informatiebeveiligings-doelstellingen
5. Feedback van belanghebbenden
6. Resultaten risicobeoordeling en behandeling
7. Kansen voor continue verbetering
8. Formele beoordeling ISMS

Input en uitkomsten van meeting

In deze meeting moet per agendapunt de inhoud gepresenteerd worden door de CISO. Het is dus handig om vooraf per inhoud de inhoud van het relevante register hier neer te zetten. Bijvoorbeeld alle interne / externe punten, alle KPI's en alle doelstellingen inclusief laatste score en stand van zaken, en grootste risico's of risico's met behandelplan.

In de meeting moet directie vragen stellen en vervolgens besluiten tot acties of andere besluiten nemen. Bijvoorbeeld extra inzet, controles, wel / niet accepteren risico's. Er moeten 3-5 concrete acties genoteerd worden en het management moet formeel het ISMS goedkeuren.

Agendapunt	Input - Vooraf ingevulde punten ter bespreking:	Output - Uitkomsten en acties genoteerd in de managementreview
Status van acties uit vorige review	De acties uit de laatste managementreview waren: 1. ...	
Wijzigingen in interne en externe onderwerpen die van belang zijn voor Informatiebeveiliging	[samenvatting of link naar overzicht interne / externe onderwerpen, evt korte samenvatting wijzigingen]	Zijn deze actueel? Wat zijn nieuwe onderwerpen?
Wijzigingen in de behoeften en verwachtingen van	[samenvatting of link naar overzicht belanghebbenden, evt korte samenvatting nieuwe	

de belanghebbenden die relevant zijn voor het ISMS	belanghebbenden, bijv door nieuwe wetgeving of nieuwe landen]	
Feedback op prestaties, gebaseerd op: Afwijkingen (uit externe audit, interne audits of andere controles)	[samenvatting van geconstateerde afwijkingen en het eigen verbeterplan / CAP hiervoor]	Is juiste actie genomen / gepland?
Feedback op prestaties, gebaseerd op: resultaat monitoren en meten	[laat dashboard van gekozen KPI's zijn met minimaal 2 meetwaarden per KPI zodat je kunt bepalen wat de trend is]	Zijn waardes voldoende? Is juiste actie genomen? Zijn de juiste KPI's gedefinieerd?
Feedback op prestaties, gebaseerd op: Auditresultaten	[samenvatting van observaties / kansen voor verbetering uit laatste externe en interne audit]	Is juiste actie genomen / gepland?
Feedback op prestaties, gebaseerd op: Evaluatie informatiebeveiligings-doelstellingen	[samenvatting van de doelstellingen en huidige status: gaat de organisatie de doelstellingen halen]	Ligt de organisatie op schema? Is juiste actie genomen? Zijn er nieuwe doelstellingen?
Feedback van belanghebbenden (stakeholder-analyse)	[noem belanghebbenden waarmee meeste contact is]	Zijn er vragen, eisen of opmerkingen van belanghebbenden over informatiebeveiliging?
Resultaten risicobeoordeling	[samenvatting van risicobeoordeling en lopende risicobehandelplannen inclusie status]	Wanneer was de laatste update? Zijn risicobehandelplannen afgerond?
Kansen voor continue verbetering		Zijn er verbeterideeën van medewerkers? Worden deze uitgevoerd? Heeft het management suggesties?

Formele besluiten uit de managementreview

De directie is tevreden met de staat van het ISMS: Het ISMS is effectief en zorgt ervoor dat de organisatie aan de norm voldoet en de doelen bereikt.

Andere besluiten (optioneel):

...

Samenvatting van genoteerde acties: